

# AWS Jam 实验总结

## CloudWatch 日志数据保护策略

本文档涵盖 AWS CloudWatch 日志组  
PII（个人可识别信息）数据保护的  
题目背景、操作步骤与核心知识点

服务：Amazon CloudWatch | 难度：入门

2026 年 3 月 9 日

## 目录

---

# 1 背景与概述

## 1.1 实验背景

在企业 AWS 环境中，Lambda 函数常将运行日志发送至 Amazon CloudWatch Logs。若开发人员在代码中不慎将用户隐私字段（如姓名、邮箱、身份证号、信用卡号等）直接打印到日志，将导致 **PII**（**Personally Identifiable Information**，个人可识别信息）泄露，违反 GDPR、CCPA 等数据合规要求。

 说明

PII 是指任何能够单独或结合其他信息识别特定个人的数据，包括姓名、电子邮件地址、社会安全号、信用卡号、IP 地址等。

## 1.2 实验目标

本次 AWS Jam 包含两个关联任务，核心目标一致：

- 识别 CloudWatch 日志组中暴露的 PII 类型
- 为对应日志组配置正确的数据保护策略（Data Protection Policy）
- 使策略生效，对敏感字段进行自动遮蔽（Masking）

## 1.3 涉及 AWS 资源

| 资源类型                 | 资源名称                                 | 说明              |
|----------------------|--------------------------------------|-----------------|
| CloudWatch Log Group | /aws/lambda/sensitive-data-01-lambda | 任务一：已有错误保护策略    |
| CloudWatch Log Group | /aws/lambda/sensitive-data-02-lambda | 任务二：需先识别 PII 类型 |

## 2 任务一：修正错误的数据保护策略

### 2.1 题目描述

日志组 `sensitive-data-01-lambda` 正在记录包含 PII 信息的日志，且已配置了错误的数据保护策略，需要将其修正为正确的策略以遮蔽敏感数据。

### 2.2 操作步骤

#### 2.2.1 步骤 1：导航至目标日志组

1. 登录 AWS Management Console
2. 搜索并进入 CloudWatch 服务
3. 在左侧导航栏选择 **Logs** → **Log groups**
4. 找到并点击 `/aws/lambda/sensitive-data-01-lambda`

#### 2.2.2 步骤 2：进入数据保护配置

1. 点击日志组详情页顶部的 **Data protection** 标签
2. 若已有旧策略，选择 **Edit** 进行修改；否则点击 **Create data protection policy**

#### 2.2.3 步骤 3：选择 PII 数据类型

在数据类型选择界面，勾选所有需要保护的 PII 类型。控制台会直接显示可选数据类型；若你手写策略 JSON，则需要使用 AWS 官方的 **managed data identifier ID**。下面列出本题最常见且名称准确的标识符（建议在 Jam 中直接控制台全选，避免漏项）：

|      | 类别 | 数据类型标识符                | 说明                  |
|------|----|------------------------|---------------------|
| 金融信息 |    | CreditCardNumber       | 信用卡号                |
|      |    | CreditCardExpiration   | 信用卡有效期              |
|      |    | CreditCardSecurityCode | CVV / Security Code |
|      |    | BankAccountNumber-US   | 区域相关，手写策略时需带国家代码    |
| 个人身份 |    | Name                   | 姓名                  |
|      |    | EmailAddress           | 电子邮件地址              |
|      |    | Address                | 邮寄地址                |

(续表)

|       | 类别 | 数据类型标识符                         | 说明                    |
|-------|----|---------------------------------|-----------------------|
|       |    | DateOfBirth                     | 出生日期                  |
|       |    | PhoneNumber-US                  | 区域相关，电话号需带国家代码        |
| 证件号码  |    | Ssn-US                          | 美国社会安全号 (SSN)         |
|       |    | PassportNumber-US               | 美国护照号                 |
|       |    | DriversLicense-US               | 美国驾照号                 |
|       |    | NationalIdentificationNumber-ES | 国家身份证号示例（需带国家代码）      |
| 网络与密钥 |    | IpAddress                       | IP 地址                 |
|       |    | AwsSecretKey                    | AWS Secret Access Key |
|       |    | OpenSshPrivateKey               | OpenSSH 私钥            |
|       |    | PgpPrivateKey                   | PGP 私钥                |
|       |    | PkcsPrivateKey                  | PKCS 私钥               |
|       |    | PuttyPrivateKey                 | PuTTY 私钥              |
| 医疗健康  |    | HealthInsuranceCardNumber-EU    | 欧盟健康保险卡号              |
|       |    | DrugEnforcementAgencyNumber-US  | DEA 药物执法编号            |

**⚠ 注意**

部分标识符是区域相关的，必须追加 ISO 3166-1 alpha-2 代码，例如 DriversLicense-US、Ssn-US、BankAccountNumber-US。

若直接在控制台勾选，控制台会帮你处理这些细节；若手写 JSON，请以 AWS 官方 managed identifier 列表为准。

**2.2.4 步骤 4：配置审计目标（可选）**

- 可选择将审计结果发送到 S3 存储桶、另一个 CloudWatch 日志组，或 Kinesis Data Firehose
- 如无需审计，可跳过此步骤

**2.2.5 步骤 5：保存并验证**

1. 点击 **Create / Save** 保存策略
2. 返回日志流，查看最新日志，PII 字段应显示为遮蔽格式

Listing 1: 策略生效后的日志示例

```
# 策略生效前
email: john.doe@example.com | ssn: 123-45-6789 | ip: 192.168.1.1

# 策略生效后
email: ***** | ssn: ***** | ip: *****
```

### 3 任务二：识别 PII 类型并应用保护策略

#### 3.1 题目描述

日志组 `sensitive-data-02-lambda` 暴露了多种 PII 字段，需要先主动查看日志内容，识别具体的 PII 类型，再针对性地配置数据保护策略以遮蔽全部敏感信息。

**⚠ 注意**

本任务与任务一的核心区别在于：需要先读取日志内容进行 PII 类型识别，再制定保护策略，而非直接套用已知配置。

#### 3.2 操作步骤

##### 3.2.1 步骤 1：查看日志内容，识别 PII

- 1. 进入 **CloudWatch** → **Log groups**
- 2. 点击 `/aws/lambda/sensitive-data-02-lambda`
- 3. 点击 **Log streams**，打开最新的日志流
- 4. 仔细阅读日志内容，记录所有暴露的敏感字段

##### 3.2.2 步骤 2：PII 类型映射

根据日志中看到的内容，对应选择保护类型：

| 日志中出现的内容                 | 对应 PII 类型        |
|--------------------------|------------------|
| user@example.com 格式字符串   | EmailAddress     |
| 555-123-4567 格式号码        | PhoneNumber-US   |
| 123-45-6789 格式编号         | Ssn-US           |
| 192.168.x.x 格式地址         | IpAddress        |
| 4111-1111-1111-1111 格式号码 | CreditCardNumber |
| 人名字符串                    | Name             |
| 街道地址字符串                  | Address          |

##### 3.2.3 步骤 3：应用数据保护策略

操作方式与任务一相同，参考第 2.2 节步骤 2-5，根据识别结果仅勾选对应类型，或直接全选以确保完整覆盖。

 最佳实践

在实验/竞赛场景中，若不确定日志包含哪些 PII 类型，建议**全选所有类型**，这是最保险的做法，可确保通过任务验证并满足最严格的合规要求。

在生产环境中，则应仅选择**实际业务涉及的 PII 类型**，避免过度遮蔽影响日志可用性。



## 4 核心知识点

### 4.1 Amazon CloudWatch Logs 数据保护策略

#### 4.1.1 功能简介

CloudWatch Logs 数据保护策略（Data Protection Policy）是 AWS 提供的托管功能，可自动检测并遮蔽日志数据中的敏感信息，无需修改应用代码。

#### 4.1.2 核心特性

- **自动检测**：基于正则模式和机器学习检测 PII
- **实时遮蔽**：新写入的日志实时进行遮蔽处理
- **不可追溯**：策略仅对新日志生效，不影响已存储的历史日志
- **审计支持**：可将检测结果输出到 S3 或其他日志组
- **权限受控**：具有特定 IAM 权限的用户可查看原始未遮蔽数据

#### 4.1.3 工作原理

Lambda 函数      →      CloudWatch Logs  
输出含 PII 的日志      数据保护策略检测并遮蔽

Listing 2: 遮蔽前后对比示意

```
# Lambda 实际输出
INFO: Processing user john.doe@example.com, SSN: 123-45-6789

# CloudWatch 日志中显示
INFO: Processing user *****, SSN: *****
```

### 4.2 所需 IAM 权限

Listing 3: 单个 Log Group 且不配置审计目标时的最小权限（JSON）

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
```

```
    "Action": [
      "logs:PutDataProtectionPolicy",
      "logs:GetDataProtectionPolicy",
      "logs>DeleteDataProtectionPolicy"
    ],
    "Resource": "arn:aws:logs:*:*:log-group:*"
  }
]
```

 说明

上述策略只覆盖单个日志组且无审计目标的最小场景。若实际操作包含以下能力，还需要额外权限：

- 配置 CloudWatch Logs 作为审计目标:还需 logs:CreateLogDelivery、logs:PutResourcePolicy、logs:DescribeResourcePolicies、logs:DescribeLogGroups
- 配置 S3 作为审计目标: 还需 logs:CreateLogDelivery、s3:GetBucketPolicy、s3:PutBucketPolicy
- 配置 Firehose 作为审计目标: 还需 logs:CreateLogDelivery，以及目标 Firehose 的相关权限
- 查看未遮蔽日志: 还需 logs:Unmask
- 创建账号级策略:还需 logs:PutAccountPolicy;删除账号级策略则需 logs>DeleteAccountPolicy

4.3 数据保护策略的局限性

| 局限项   | 说明                                      |
|-------|-----------------------------------------|
| 历史日志  | 策略不追溯处理已存储的历史日志                         |
| 日志组类别 | 仅 <b>Standard log class</b> 支持 masking  |
| 区域限制  | 需在支持该功能的 AWS 区域内使用                      |
| 误遮蔽风险 | 全选 PII 类型可能遮蔽部分非 PII 字段                 |
| 查看权限  | 默认只能看到遮蔽后的数据；具备 logs:Unmask 的用户可查看未遮蔽内容 |

4.4 数据合规相关法规

- **GDPR**（欧盟通用数据保护条例）：要求对个人数据进行最小化收集和保护

- **CCPA**（加州消费者隐私法）：赋予消费者对个人数据的知情权和控制权
- **HIPAA**（健康保险可携带性和责任法案）：规范医疗健康数据的处理方式
- **PCI DSS**（支付卡行业数据安全标准）：规范信用卡数据的存储与传输

## 5 操作速查表

### ✓ 最佳实践

以下为快速参考，适用于考试或竞赛场景中的快速操作。

- Step 1. 进入 CloudWatch: Console → CloudWatch → Log groups
- Step 2. 选择日志组: 点击目标 Log Group 名称
- Step 3. 查看日志 (任务二): Log streams → 最新流 → 识别 PII 字段
- Step 4. 创建策略: Actions → Create data protection policy
- Step 5. 选择类型: 全选或按需勾选 PII 数据类型
- Step 6. 保存: 点击 Create / Save
- Step 7. 验证: 返回日志流, 确认敏感字段已被星号遮蔽

---

本文档根据 AWS Jam 实验场景整理, 仅供学习参考。

Amazon CloudWatch 功能以 AWS 官方文档为准: [docs.aws.amazon.com](https://docs.aws.amazon.com)